

SmartPR

Security & Trust Package

Enterprise security, data protection, AI governance, and assurance readiness

Security posture	SmartPR has substantive application-layer security controls in place, including server-side role enforcement, workspace isolation, enterprise identity features, privileged-access controls, audit logging, and secret-handling safeguards. The current program is best described as SOC 2 readiness in progress: several production infrastructure and operating-control items still require verification and evidence before independent attestation.
------------------	---

Prepared for: Prospective customers, enterprise security teams, procurement, IT, compliance, and business stakeholders

Review date: September 17, 2026

Assurance status: SOC 2 readiness program; no SOC 2 certification or attestation claim

Scope note: This package summarizes controls evidenced in the SmartPR application codebase and security documentation. Hosting configuration, live identity-provider settings, database policy coverage, vendor attestations, and backup/restore controls are verified separately during customer diligence.

1. Security posture at a glance

SmartPR is built as a multi-tenant regulatory intelligence and workflow platform. Security controls are implemented across authentication, authorization, tenant isolation, privileged access, auditability, integration credentials, and enterprise identity. The platform also maintains a structured security-control registry, incident/risk/policy records, and evidence-tracking mechanisms to support a formal assurance program.

Area	Current status	Client-facing summary
Authentication & sessions	Implemented	Application authentication is handled through Supabase Auth with server-side session handling.
Workspace RBAC	Implemented	Workspace and enterprise permissions are enforced on server-side APIs.
Tenant isolation	Implemented / verify prod	Application-layer workspace scoping is present; production RLS coverage is validated separately.
SSO / SCIM	Available / verify prod	Enterprise SSO controls and SCIM provisioning are implemented; customer IdP wiring is environment-specific.
Privileged support access	Implemented	Support access is reason-bound, time-limited, read-only by default, and audited.
Audit logging	Implemented	Sensitive enterprise and administrative actions generate audit events; key audit records are designed to be append-only.
Secrets & service accounts	Implemented	Service-account credentials are hash-stored; rotation/revocation and scoped access are supported.
AI governance	Program in place	AI usage is documented with data-minimization and no-raw-confidential-logging guidance; provider terms require contract verification.
Vulnerability management	Readiness process	A documented process and evidence model exist; continuous production scanning evidence is being operationalized.
SOC 2	Readiness only	Controls are mapped for readiness; SmartPR does not currently claim a SOC 2 report or certification.

What this means for customers

- The platform already includes enterprise controls that matter for production use: role enforcement, tenant scoping, identity lifecycle support, auditability, and privileged-access restrictions.
- SmartPR can participate in customer security due diligence with a documented control inventory and evidence framework.
- Independent assurance is a separate workstream. SmartPR does not represent readiness artifacts as a SOC 2 report.

2. Identity, access, and tenant protection

Authentication and enterprise identity

- User authentication is integrated with Supabase Auth and application middleware handles authenticated sessions.
- Enterprise workspaces support SSO configuration and domain-based enforcement controls.
- SCIM 2.0 provisioning supports managed user and group lifecycle workflows using scoped service-account credentials.
- MFA policy configuration is represented in the enterprise security posture; production enrollment/enforcement is validated at the identity-provider layer.

Authorization and least privilege

- Workspace access is role-based, with explicit Owner, Admin, Member, and Viewer behavior plus enterprise permission scopes.
- Sensitive enterprise and administrative APIs enforce authorization server-side rather than relying only on UI visibility.
- Machine credentials support scopes, expiration, revocation, fingerprints, and last-use tracking.

Tenant isolation

SmartPR scopes enterprise operations to a workspace and uses centralized permission checks before workspace data is read or changed. Database-level row security is part of the architecture; complete production RLS coverage is treated as a deployment verification item, not assumed from repository code alone.

Privileged support access

- Support access requires a reason and a defined duration.
- Read-only is the default support scope.
- Expiration is enforced; support access does not create ordinary workspace membership.
- Grant, use, revoke, and expiry-related activity is designed to be auditable.

Customer configuration options

- SSO / SAML connection configuration
- SCIM provisioning and group-to-role mapping
- Session and MFA policy configuration
- Role-based access and separation of duties
- Audit-log access for authorized enterprise users

3. Data protection, auditability, and integrations

Auditability

SmartPR records security-relevant administrative and enterprise events. The platform includes an enterprise audit model, superadmin audit logging, and security event taxonomy for privileged actions. Secret-like fields are redacted before being included in audit payloads.

Credential and secret safeguards

- Service-account secrets are designed to be shown only at creation/rotation and stored as hashes rather than recoverable plaintext.
- Revoked or expired machine credentials are rejected.
- Webhook signing secrets are protected with AES-256-GCM when application-managed storage is used.
- Outbound webhook integrity can be protected with HMAC-SHA256 signatures.
- Server-side secret-redaction helpers reduce the risk of credentials leaking through logs or API responses.

Data hosting and storage

The application uses managed infrastructure providers for authentication, database/storage, application hosting, billing, AI services, and optional automation. Specific production encryption, backup retention, region, RPO/RTO, and vendor assurance details are confirmed from the applicable provider configuration and reports during diligence.

Subprocessors observed in the current platform

Provider	Primary purpose	Typical data category
Supabase	Authentication, PostgreSQL, file storage	Account, workspace, application and evidence data
Railway	Application / worker hosting	Runtime data, logs, environment configuration
xAI	AI model processing	Prompt content derived from user/business context
Stripe	Billing and subscriptions	Billing identifiers and payment-related tokens
Google / Gmail SMTP	Operational notifications	Notification / lead content
Browser Use (optional)	Agency browser automation	Configured page/session content and telemetry

Subprocessor note: This is a technical inventory, not a contractual subprocessor schedule. Contractual status, DPAs, data residency, and vendor assurance reports are confirmed during onboarding.

4. AI and customer data governance

SmartPR uses AI to interpret regulatory context, assist with application preparation, and support selected automation workflows. Customer information used in AI-assisted features is treated as confidential application data.

Current engineering principles

- AI requests remain subject to the same authentication and workspace-access controls as other application functions.
- The security logging abstraction is designed to capture operational metadata without logging raw confidential prompt content.
- AI integrations use server-side provider credentials; provider secrets are not intended for client-side exposure.
- The platform's internal guidance requires minimizing the customer information transmitted to an AI provider to what is needed for the operation.
- SmartPR does not train foundation models from the application repository or operate a first-party foundation-model training pipeline.

Enterprise diligence items

Before making contractual commitments regarding AI-provider training, retention, geographic processing, or deletion, SmartPR validates the applicable provider terms and configuration. These commitments should be documented in the customer agreement or data-processing terms rather than inferred from the application code.

AI questions SmartPR can address during diligence

- Which AI providers are used for the customer's enabled features?
- What categories of customer data can be sent to a model?
- Are raw documents required, or can processing be limited to extracted fields?
- What provider retention/training terms apply to the contracted API service?
- Can specific features or data flows be restricted for an enterprise deployment?

5. Security operations and assurance

Security governance framework

SmartPR maintains a machine-readable control registry and internal workflows for security evidence, access reviews, incidents, risks, and policies. The purpose is to move from 'security features exist' to 'security controls can be demonstrated and reviewed over time.'

- Privileged access review workflow and evidence capture
- Security incident register and incident-response plan
- Security risk register
- Policy register and review dates
- Change/deployment evidence model
- Vulnerability-management process and remediation tracking
- Backup/restore evidence model

SOC 2 status

Current status	SmartPR maintains SOC 2 readiness materials and control mappings. SmartPR does not currently claim SOC 2 certification, attestation, or an issued SOC 2 report. Formal assurance requires an independent examination by a licensed CPA firm.
----------------	--

Readiness items being independently verified

- Production database row-level security coverage
- Production identity-provider SSO and MFA enforcement
- Backup retention, recovery capabilities, and restore testing
- GitHub branch protection and required CI security checks
- Vendor SOC / security reports and contractual data-processing terms
- Recurring vulnerability scan evidence and operating cadence

Customer assurance materials available or supportable

- Security & Trust overview
- Technical security questionnaire responses
- Subprocessor and AI data-flow review
- Identity / SSO / SCIM architecture discussion
- Role and permissions matrix
- Audit-log and privileged-access walkthrough
- SOC 2 readiness status and assurance roadmap

6. Security diligence FAQ

Is SmartPR SOC 2 certified?

No. SmartPR currently maintains SOC 2 readiness documentation and control mappings but does not claim an issued SOC 2 report or certification.

Does SmartPR support enterprise identity?

Yes. The product includes enterprise SSO controls and SCIM provisioning. Live customer IdP configuration is validated as part of deployment.

How is access to customer workspaces controlled?

Workspace and enterprise permissions are enforced server-side. Roles and permission scopes restrict who can view, change, approve, or administer information.

Can SmartPR support staff access customer data?

Privileged support access is designed to be explicit, reason-bound, time-limited, read-only by default, and auditable rather than permanent background access.

Are administrative actions logged?

Yes. The platform contains administrative and enterprise audit mechanisms for sensitive actions, with redaction safeguards for secret-like values.

How are API/service credentials handled?

Service-account credentials are hash-stored, scoped, revocable, and expirable, with fingerprints and last-use tracking. Raw credentials are intended to be displayed only at creation or rotation.

Does SmartPR use AI providers?

Yes. AI-assisted features use third-party model services. The applicable provider, data categories, and contractual retention/training terms are reviewed during enterprise diligence.

Where is customer data hosted?

SmartPR uses managed cloud providers including Supabase and Railway. Production region, encryption, backup, and recovery configuration is confirmed for the applicable environment during diligence.

Can SmartPR complete a security questionnaire?

Yes. SmartPR maintains a control inventory and evidence model intended to support customer security, privacy, IT, and procurement reviews.

Important assurance statement

This document is an informational security overview, not an audit opinion, certification, warranty, or substitute for contractual security terms. Control availability may depend on deployment configuration and customer-selected features. SmartPR will validate environment-specific claims during formal due diligence.